1. Что сделано

На одном маршрутизаторе Cisco (IOS 15.9) построена сеть малого предприятия из четырёх сегментов: пользователи, внутренние серверы, демилитаризованная зона (DMZ) с веб-сервером и внешняя сеть с выходом в Интернет. Маршрутизатор стоит между сегментами и решает, кому с кем можно соединяться. Работа выполнена на стенде в Cisco Modeling Labs с настоящим образом Cisco IOS.

Задание состояло из семи пунктов. Что сделано по каждому, показано в таблице 1.

Таблица 1 – Пункты задания и результат

№	Пункт задания	Что сделано	Раздел курсовой работы
1	Адресация и маршрутизация	Четыре сети на четырёх интерфейсах, маршрут по умолчанию к провайдеру	3.1
2	Защита управления	Пароли scrypt, SSH версии 2 только из сети пользователей, блокировка подбора пароля, журнал команд	3.2
3	Защита от подмены адресов	Проверка обратного пути uRPF и входной список на внешнем интерфейсе	3.3
4	Разграничение доступа	Межсетевой экран на зонах: 4 зоны, 20 пар зон, запрет по умолчанию	3.4
5	Выход в Интернет, публикация сервера	PAT для внутренних сетей, статическая трансляция для веб-сервера	3.5
6	Учёт событий	Время по NTP, журнал на отдельном сервере	3.6
7	Проверка защиты	60 проверок «до и после» и 8 атак с внешнего узла	4

2. Как устроена сеть

Схема сети показана на рисунке 1. Каждый сегмент подключён к своему интерфейсу маршрутизатора R1, поэтому любой обмен между сегментами проходит через него.

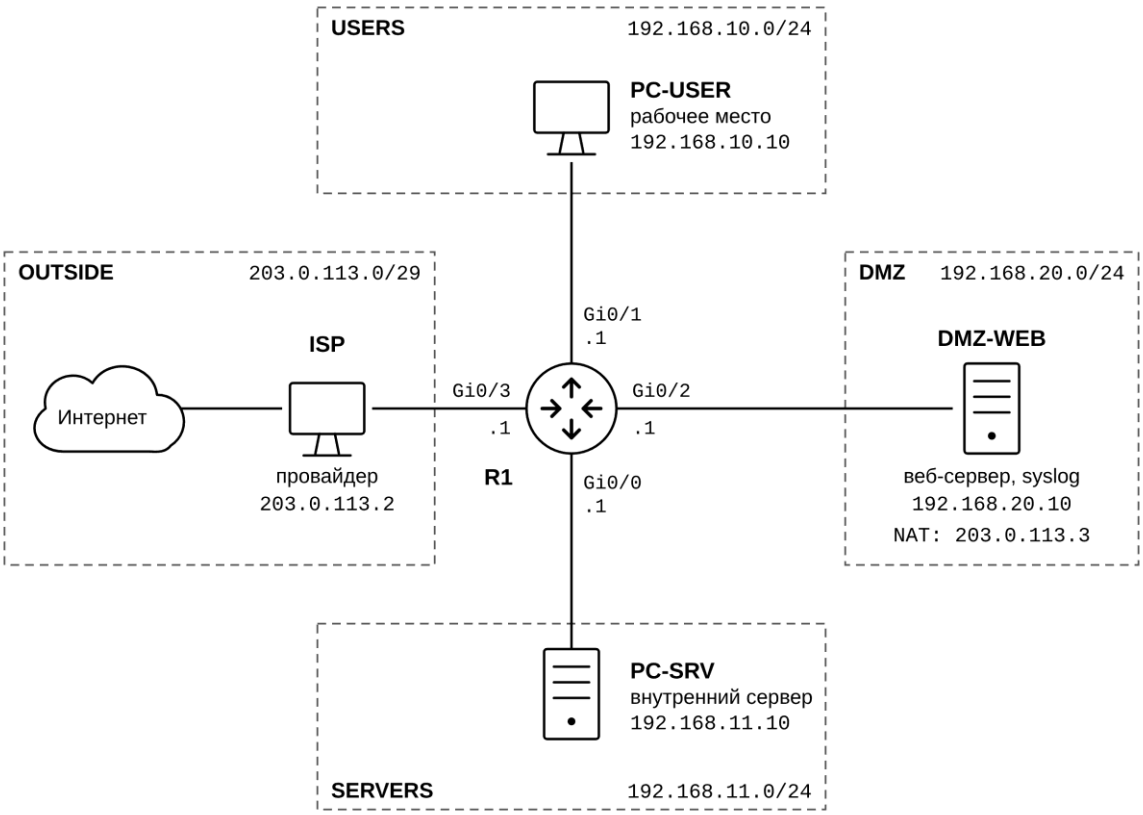


Рисунок 1 – Схема сети

Таблица 2 – Узлы и их роли

Узел	Сегмент	Адрес	Роль
R1	–	.1 в каждой сети	Пограничный маршрутизатор и межсетевой экран
PC-USER	USERS	192.168.10.10	Рабочее место сотрудника и администратора. Клиент, которому DMZ доступна
PC-SRV	SERVERS	192.168.11.10	Узел сегмента внутренних серверов. Клиент, которому DMZ недоступна
DMZ-WEB	DMZ	192.168.20.10	Веб-сервер, виден из Интернета как 203.0.113.3. Он же сервер журналов
ISP	OUTSIDE	203.0.113.2	Провайдер и внешний пользователь; при проверках – источник атак

Правила доступа между сегментами приведены в таблице 3. В строках указан источник соединения, в столбцах – назначение. Ответы на разрешённые соединения проходят автоматически.

Таблица 3 – Кто имеет право начинать соединение

Откуда \ куда	USERS	SERVERS	DMZ	Интернет	R1
USERS	–	SSH, HTTP, HTTPS, ping	разрешено	разрешено	SSH, ping
SERVERS	запрещено	–	запрещено	разрешено	ping
DMZ	запрещено	запрещено	–	разрешено	ping
Интернет	запрещено	запрещено	только TCP 80 и 443	–	запрещено
R1	разрешено	разрешено	разрешено	разрешено	–

3. Какие сервисы работают в сети

Сервисы, участвующие в работе сети, перечислены в таблице 4. Для каждого указано, где он работает и кому доступен.

Таблица 4 – Сервисы сети

Сервис	Где работает	Протокол, порт	Назначение	Кому доступен
Веб-сервер nginx	DMZ-WEB	TCP 80 (HTTP), TCP 443 (HTTPS)	Сайт предприятия	Интернет и сеть пользователей
Удалённое управление SSH	R1	TCP 22	Настройка маршрутизатора	Только сеть пользователей
Межсетевой экран на зонах	R1	–	Разграничение доступа между сегментами	Действует на весь трафик
Трансляция адресов: PAT и static NAT	R1	–	Выход в Интернет, публичный адрес веб-сервера	Все внутренние сегменты
Сервер журналов rsyslog	DMZ-WEB	UDP 514	Хранение журнала маршрутизатора вне его	Принимает записи только от R1
Синхронизация времени NTP	R1 – клиент; три сервера в Интернете	UDP 123	Единое время в журналах	R1 обменивается только с тремя заданными серверами
Разрешение имён DNS	Внешний сервер 8.8.8.8	UDP 53	Имена сайтов для узлов сети	Все узлы, через трансляцию
Диагностика ICMP (ping)	Все узлы	ICMP	Проверка связи	По правилам экрана; из Интернета закрыта
Трансляция у провайдера	ISP	–	Заменяет сеть провайдера, выводит стенд в реальный Интернет	Вне настроек R1

Адреса узлам заданы статически, сервера DHCP в сети нет. Централизованной аутентификации и удалённого доступа по VPN в работе также нет.

4. Настройка маршрутизатора

Настройка выполнена в шесть шагов, по пунктам задания. Для каждого шага приведены введённые команды с пояснениями и проверка результата. Пакет, пришедший из Интернета, проходит настроенные рубежи защиты в порядке, показанном на рисунке 2.



Рисунок 2 – Порядок обработки пакета, пришедшего из Интернета

4.1. Адресация и маршрутизация

Маршрутизатору присвоено имя, на четырёх интерфейсах заданы адреса и описания, интерфейсы включены. Для выхода во внешнюю сеть задан маршрут по умолчанию через адрес провайдера (листинг 1). Сети, подключённые к интерфейсам напрямую, попадают в таблицу маршрутизации автоматически.

Листинг 1 – Базовая настройка R1

```
hostname R1
! Не искать опечатки в командах как имена узлов в DNS
no ip domain lookup
!
interface GigabitEthernet0/0
 description INSIDE-SERVERS
 ip address 192.168.11.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/1
 description INSIDE-USERS
 ip address 192.168.10.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/2
 description DMZ
 ip address 192.168.20.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/3
 description OUTSIDE
 ip address 203.0.113.1 255.255.255.248
 no shutdown
!
! Маршрут по умолчанию: всё, что не в своих сетях, - провайдеру
ip route 0.0.0.0 0.0.0.0 203.0.113.2
!
! Сообщения журнала не разрывают вводимую команду
line con 0
 logging synchronous
```

Все четыре интерфейса имеют адреса и находятся в состоянии up (рисунок 3). В таблице маршрутизации четыре подключённые сети и маршрут по умолчанию (рисунок 4).

```
R1#show ip interface brief
Interface                  IP-Address      OK? Method Status                Protocol
GigabitEthernet0/0         192.168.11.1    YES manual up                    up
GigabitEthernet0/1         192.168.10.1    YES manual up                    up
GigabitEthernet0/2         192.168.20.1    YES manual up                    up
GigabitEthernet0/3         203.0.113.1     YES manual up                    up
R1#
```

Рисунок 3 – Состояние интерфейсов R1

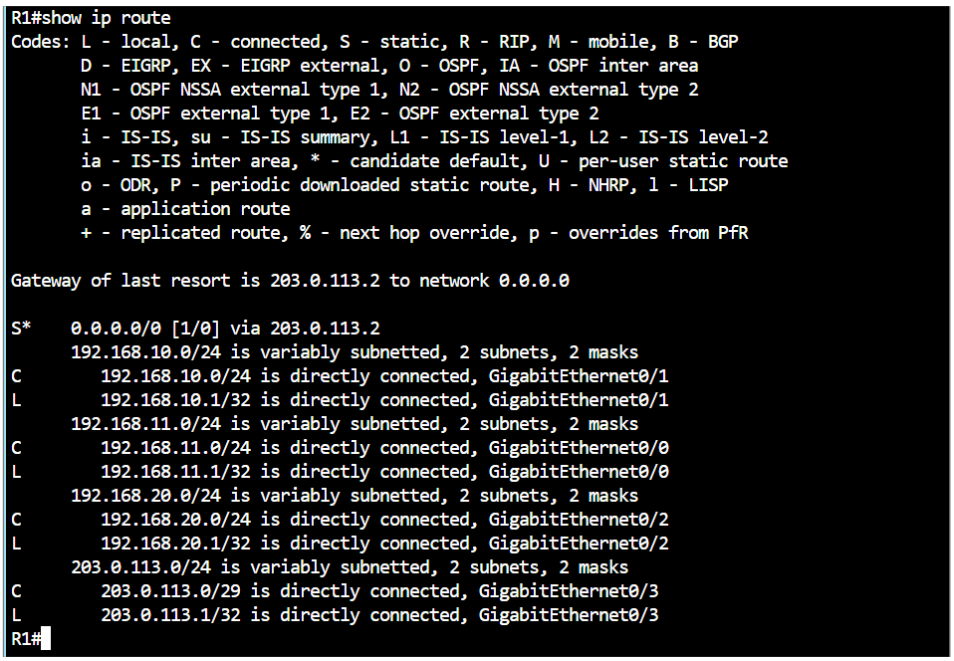


Рисунок 4 – Таблица маршрутизации R1

После этого шага маршрутизатор пересылает пакеты между всеми сегментами без ограничений. Сеть работает, но не защищена; это исходное состояние для всех дальнейших проверок.

4.2. Защита управления маршрутизатором

Пароли и учётные записи. Сначала задана минимальная длина пароля, затем сами пароли. Они хранятся в виде хеша scrypt (тип 9). Вход выполняется по персональной учётной записи, поэтому в журнале видно, кто именно вошёл и что изменил (листинг 2).

Листинг 2 – Пароли и учётная запись администратора

```
! Пароли короче 10 символов отклоняются
security passwords min-length 10
! Пароль привилегированного режима, хеш scrypt (тип 9)
enable algorithm-type scrypt secret <ПАРОЛЬ>
! Персональная учётная запись администратора, уровень 15
username admin privilege 15 algorithm-type scrypt secret <ПАРОЛЬ>
! Скрыть оставшиеся пароли открытого типа (тип 7)
service password-encryption
```

SSH. Создан ключ RSA длиной 2048 бит, разрешена только вторая версия протокола, из списка алгоритмов исключены устаревшие (листинг 3). Результат показан на рисунке 5.

Листинг 3 – Настройка SSH

```
ip domain name lab.local
! Пара ключей RSA 2048 бит с именем R1.lab.local
crypto key generate rsa general-keys modulus 2048
ip ssh rsa keypair-name R1.lab.local
! Только SSH версии 2
ip ssh version 2
! 60 секунд на вход, не более 3 попыток пароля за соединение
ip ssh time-out 60
ip ssh authentication-retries 3
! Группа Диффи-Хеллмана не менее 2048 бит
ip ssh dh min size 2048
! Записывать события SSH в журнал
ip ssh logging events
! Разрешённые алгоритмы
ip ssh server algorithm encryption aes256-ctr aes192-ctr aes128-ctr
ip ssh server algorithm mac hmac-sha2-512 hmac-sha2-256
ip ssh server algorithm kex diffie-hellman-group14-sha1
! Разрывать зависшие TCP-соединения
service tcp-keepalives-in
service tcp-keepalives-out
```

```
R1#show ip ssh
SSH Enabled - version 2.0
Authentication methods:publickey,keyboard-interactive,password
Authentication Publickey Algorithms:x509v3-ssh-rsa,ssh-rsa
Hostkey Algorithms:x509v3-ssh-rsa,ssh-rsa
Encryption Algorithms:aes256-ctr,aes192-ctr,aes128-ctr
MAC Algorithms:hmac-sha2-512,hmac-sha2-256
KEX Algorithms:diffie-hellman-group14-sha1
Authentication timeout: 60 secs; Authentication retries: 3
Minimum expected Diffie Hellman key size : 2048 bits
```

Рисунок 5 – Параметры SSH после настройки

Кто может подключаться. Удалённое управление разрешено только по SSH и только из сети пользователей, где находится рабочее место администратора. Отклонённые попытки записываются в журнал (листинг 4).

Листинг 4 – Ограничение доступа к линиям vty

```
ip access-list standard MGMT-ACCESS
 permit 192.168.10.0 0.0.0.255
 deny   any log
!
line vty 0 4
 ! Подключаться можно только с адресов из списка
 access-class MGMT-ACCESS in
 ! Только SSH; Telnet не принимается
 transport input ssh
 ! Вход по локальным учётным записям
 login local
 ! Закрывать сеанс после 5 минут бездействия
 exec-timeout 5 0
```

Подключение из сети серверов отклоняется (рисунок 6), в журнале маршрутизатора остаётся запись с адресом источника (рисунок 7).

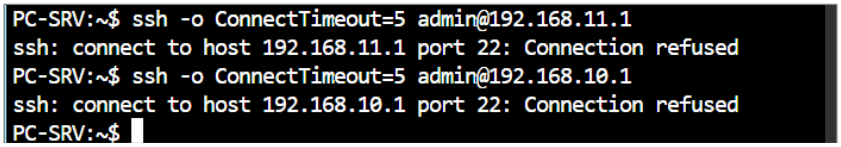


Рисунок 6 – Подключение по SSH из сети серверов отклонено



Рисунок 7 – Записи журнала и счётчики списка MGMT-ACCESS

Подбор пароля. После трёх неудачных попыток за 60 секунд маршрутизатор на 120 секунд перестаёт принимать подключения (листинг 5). На рисунке 8 показана проверка программой подбора паролей hydra из сети пользователей: после трёх попыток остальные получают отказ.

Листинг 5 – Блокировка входа при подборе пароля

```
! 3 неудачи за 60 с -> тихий режим на 120 с
login block-for 120 attempts 3 within 60
! Записывать неудачные и успешные входы
login on-failure log
login on-success log
```

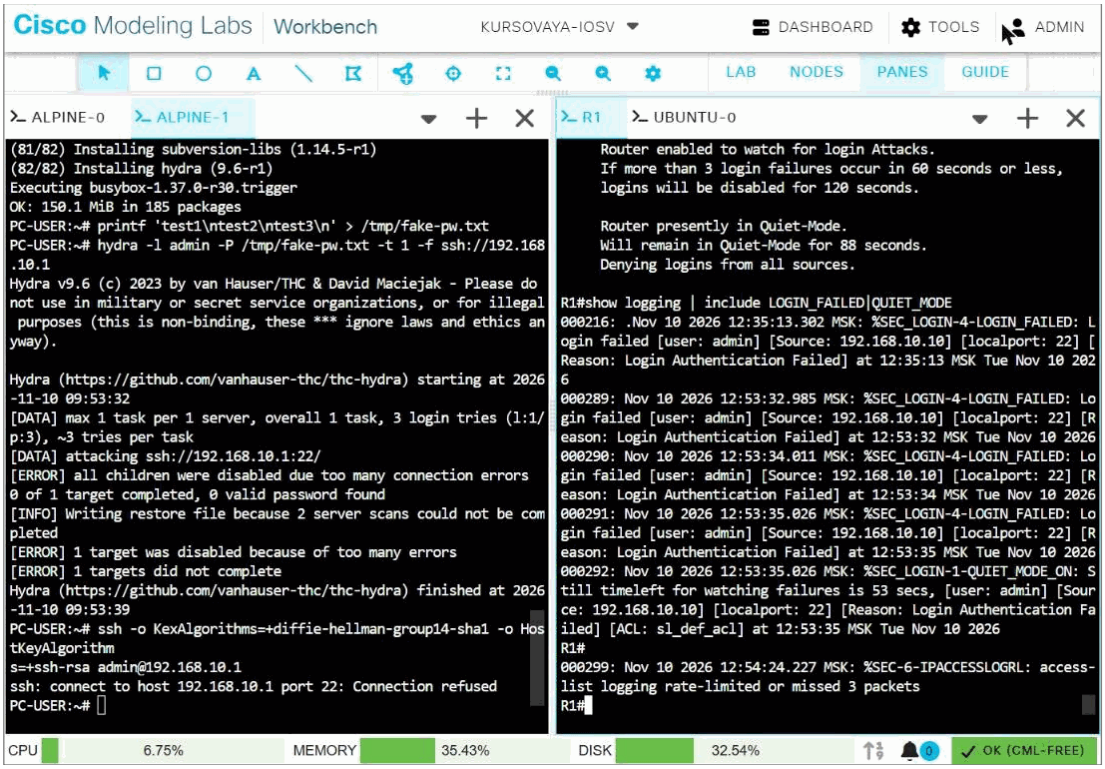


Рисунок 8 – Подбор пароля остановлен блокировкой входа

Службы, предупреждение, консоль. Неиспользуемые службы отключены. Перед входом выводится предупреждение. На консоли включён вход по учётной записи (листинг 6).

Листинг 6 – Отключение служб, предупреждение, защита консоли

```
! Встроенный веб-сервер
no ip http server
no ip http secure-server
! CDP сообщает соседям модель и версию устройства
no cdp run
! Пакеты с маршрутом, заданным отправителем
no ip source-route
! Устаревшие службы
no service pad
no ip bootp server
!
banner login ^
WARNING: Authorized access only.
All activity on this device is logged and monitored.
Disconnect now if you are not an authorized user.
^
!
line con 0
 login local
 exec-timeout 10 0
```

Журнал команд и роль аудитора. Каждая команда конфигурации записывается с именем пользователя, пароли в записях скрыты. Для

проверяющего создана учётная запись с уровнем привилегий 5: она позволяет читать журнал, но не менять настройки (листинг 7, рисунок 9).

Листинг 7 – Журнал изменений конфигурации и роль аудитора

```
! Номер и время в каждой записи журнала
service sequence-numbers
service timestamps log datetime msec
!
archive
 log config
  ! Записывать каждую команду конфигурации
  logging enable
  logging size 200
  ! Дублировать записи в системный журнал
  notify syslog contenttype plaintext
  ! Не показывать пароли
  hidekeys
!
! Аудитор: уровень 5, из дополнительных команд - только просмотр журнала
privilege exec level 5 show logging
username auditor privilege 5 algorithm-type scrypt secret <ПАРОЛЬ>
```

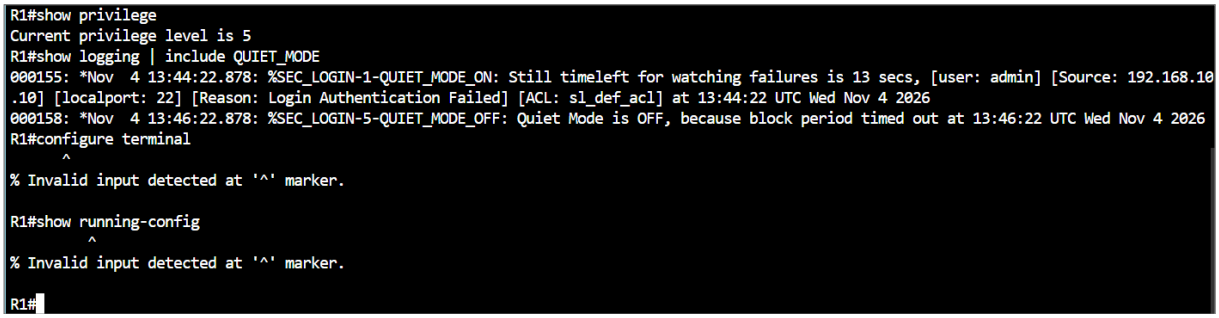


Рисунок 9 – Аудитор читает журнал, но настройка ему недоступна

4.3. Защита от подмены адресов

На каждом интерфейсе включена проверка обратного пути: пакет принимается, только если маршрут к его источнику ведёт через тот же интерфейс. На внешнем интерфейсе добавлено слово `allow-default`, потому что адреса Интернета достижимы только по маршруту по умолчанию. Там же применён входной список OUTSIDE-IN. Он отбрасывает пакеты с частными, служебными и собственными адресами источника: из Интернета такие прийти не могут (листинг 8).

Листинг 8 – Проверка обратного пути и список OUTSIDE-IN

```
interface GigabitEthernet0/0
 ip verify unicast source reachable-via rx
interface GigabitEthernet0/1
 ip verify unicast source reachable-via rx
interface GigabitEthernet0/2
 ip verify unicast source reachable-via rx
interface GigabitEthernet0/3
 ip verify unicast source reachable-via rx allow-default
!
ip access-list extended OUTSIDE-IN
 remark Anti-spoofing: private sources (RFC 1918)
 deny   ip 10.0.0.0 0.255.255.255 any log
 deny   ip 172.16.0.0 0.15.255.255 any log
 deny   ip 192.168.0.0 0.0.255.255 any log
 remark Anti-spoofing: special-use sources
 deny   ip 0.0.0.0 0.255.255.255 any log
 deny   ip 127.0.0.0 0.255.255.255 any log
 deny   ip 169.254.0.0 0.0.255.255 any log
 deny   ip 224.0.0.0 15.255.255.255 any log
 deny   ip 240.0.0.0 15.255.255.255 any log
 remark Anti-spoofing: our own addresses
 deny   ip host 203.0.113.1 any log
 deny   ip host 203.0.113.3 any log
 remark Everything else passes
 permit ip any any
!
interface GigabitEthernet0/3
 ip access-group OUTSIDE-IN in
```

На внешнем интерфейсе также отключены функции, которые помогают разведке (листинг 9).

Листинг 9 – Настройки внешнего интерфейса

```
interface GigabitEthernet0/3
 no ip redirects
 no ip unreachables
 no ip proxy-arp
```

Проверка внутри сети: узел PC-SRV отправил пакеты от имени адреса из сети пользователей. До настройки они доходили до сервера DMZ, после настройки отброшены; счётчик проверки обратного пути на интерфейсе Gi0/0 показывает три пакета (рисунок 10).

```
R1#show ip interface GigabitEthernet0/0 | include verif
  IP verify source reachable-via RX
   3 verification drops
   0 suppressed verification drops
   0 verification drop-rate
R1#show ip interface GigabitEthernet0/3 | include verif
  IP verify source reachable-via RX, allow default
   0 verification drops
   0 suppressed verification drops
   0 verification drop-rate
R1#show ip access-lists OUTSIDE-IN
Extended IP access list OUTSIDE-IN
    10 deny ip 10.0.0.0 0.255.255.255 any log (3 matches)
    20 deny ip 172.16.0.0 0.15.255.255 any log
    30 deny ip 192.168.0.0 0.0.255.255 any log (3 matches)
    40 deny ip 0.0.0.0 0.255.255.255 any log
    50 deny ip 127.0.0.0 0.255.255.255 any log
    60 deny ip 169.254.0.0 0.0.255.255 any log
    70 deny ip 224.0.0.0 15.255.255.255 any log
    80 deny ip 240.0.0.0 15.255.255.255 any log
    90 deny ip host 203.0.113.1 any log
    100 deny ip host 203.0.113.3 any log
    110 permit ip any any (4 matches)
R1#$erface GigabitEthernet0/3 | include redirects|unreachables|Proxy ARP
  Proxy ARP is disabled
  Local Proxy ARP is disabled
  ICMP redirects are never sent
  ICMP unreachables are never sent
R1#
```

Рисунок 10 – Счётчики проверки обратного пути и списка OUTSIDE-IN

Проверка снаружи: узел ISP отправил пакеты от имени рабочего места пользователя и от имени самого маршрутизатора. Все пакеты потеряны, счётчики списка выросли ровно на число отправленных пакетов (рисунок 11).

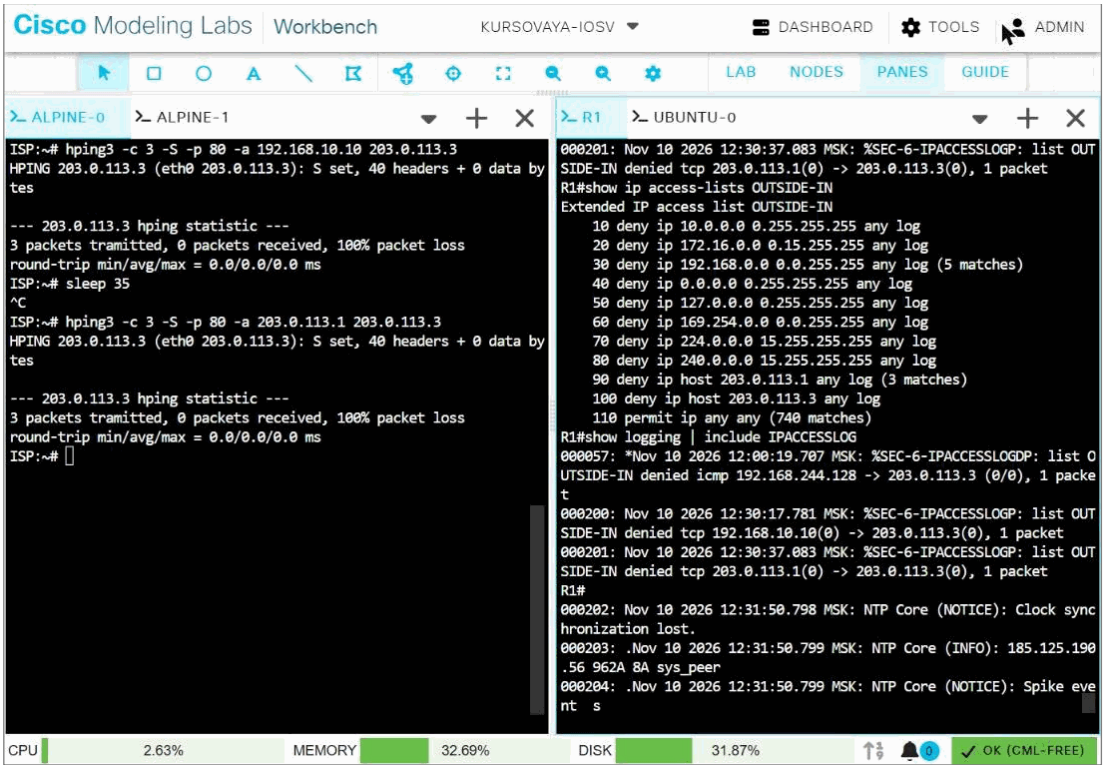


Рисунок 11 – Пакеты с поддельным адресом источника отброшены

На этом же шаге командой `secure boot-config` включена защищённая копия конфигурации: скрытый файл во флеш-памяти, из которого конфигурацию можно восстановить, если её сотрут.

4.4. Межсетевой экран на зонах

Экран строится из четырёх видов объектов. Зона объединяет интерфейсы одного сегмента. Карта классов описывает, какой это трафик. Карта политики задаёт, что с ним делать. Пара зон привязывает политику к одному направлению.

Сначала созданы зоны и описан разрешаемый трафик (листинг 10). В списке для веб-сервера указан его настоящий адрес 192.168.20.10: к моменту проверки экраном публичный адрес уже заменён трансляцией.

Листинг 10 – Зоны, списки доступа и карты классов

```
zone security USERS
zone security SERVERS
zone security DMZ
zone security OUTSIDE
!
ip access-list extended ACL-USERS-SRV
 remark USERS to SERVERS: admin and service ports only
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq 22
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq www
 permit tcp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 eq 443
 permit icmp 192.168.10.0 0.0.0.255 192.168.11.0 0.0.0.255 echo
ip access-list extended ACL-DMZ-WEB
 remark OUTSIDE to DMZ: published web server only (real address)
 permit tcp any host 192.168.20.10 eq www
 permit tcp any host 192.168.20.10 eq 443
!
! Любой трафик TCP, UDP, ICMP (достаточно одного совпадения)
class-map type inspect match-any CM-ALL
 match protocol tcp
 match protocol udp
 match protocol icmp
class-map type inspect match-all CM-USERS-SRV
 match access-group name ACL-USERS-SRV
class-map type inspect match-all CM-DMZ-WEB
 match access-group name ACL-DMZ-WEB
```

В политиках разрешённый трафик получает действие `inspect`: он пропускается, а сессия запоминается, поэтому ответы проходят сами. Всё остальное получает `drop log`: пакет отбрасывается, отказ учитывается счётчиком и записывается в журнал (листинг 11).

Листинг 11 – Карты политик для обмена между сегментами

```
! Аудит: записывать начало и конец каждой сессии
parameter-map type inspect PAR-AUDIT
 audit-trail on
!
! Разрешить всё с отслеживанием сессий
policy-map type inspect PM-INSPECT-ALL
 class type inspect CM-ALL
  inspect
 class class-default
  drop log
! Пользователи -> внутренние серверы: только служебные порты
policy-map type inspect PM-USERS-SRV
 class type inspect CM-USERS-SRV
  inspect
 class class-default
  drop log
! Интернет -> DMZ: только веб-сервер, с аудитом сессий
policy-map type inspect PM-OUT-DMZ
 class type inspect CM-DMZ-WEB
  inspect PAR-AUDIT
 class class-default
  drop log
! Полный запрет с записью в журнал
policy-map type inspect PM-DROP-LOG
 class class-default
  drop log
```

Для каждого из двенадцати направлений между четырьмя зонами создана пара зон. Запрещённые направления тоже описаны парами, чтобы каждый отказ был виден. Интерфейсы включены в зоны в последнюю очередь: только с этого момента экран начинает действовать (листинг 12).

Листинг 12 – Пары зон между сегментами и включение интерфейсов в зоны

```
! Разрешённые направления
zone-pair security ZP-USERS-SERVERS source USERS destination SERVERS
 service-policy type inspect PM-USERS-SRV
zone-pair security ZP-USERS-DMZ source USERS destination DMZ
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-USERS-OUTSIDE source USERS destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-SERVERS-OUTSIDE source SERVERS destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-DMZ-OUTSIDE source DMZ destination OUTSIDE
 service-policy type inspect PM-INSPECT-ALL
zone-pair security ZP-OUTSIDE-DMZ source OUTSIDE destination DMZ
 service-policy type inspect PM-OUT-DMZ
! Запрещённые направления
zone-pair security ZP-SERVERS-USERS source SERVERS destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-SERVERS-DMZ source SERVERS destination DMZ
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-DMZ-USERS source DMZ destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-DMZ-SERVERS source DMZ destination SERVERS
 service-policy type inspect PM-DROP-LOG
```

```
zone-pair security ZP-OUTSIDE-USERS source OUTSIDE destination USERS
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-OUTSIDE-SERVERS source OUTSIDE destination SERVERS
 service-policy type inspect PM-DROP-LOG
!
interface GigabitEthernet0/0
 zone-member security SERVERS
interface GigabitEthernet0/1
 zone-member security USERS
interface GigabitEthernet0/2
 zone-member security DMZ
interface GigabitEthernet0/3
 zone-member security OUTSIDE
```

Отдельно защищён сам маршрутизатор. Для этого созданы восемь пар со встроенной зоной `self`: из сети пользователей к маршрутизатору разрешены SSH и ping, из сетей серверов и DMZ – только ping, из внешней сети – ничего (листинг 13).

Листинг 13 – Политики и пары зон для трафика самого маршрутизатора

```
ip access-list extended ACL-MGMT-SSH
 remark USERS to R1: SSH only (vty access-class still applies)
 permit tcp 192.168.10.0 0.0.0.255 any eq 22
class-map type inspect match-all CM-MGMT-SSH
 match protocol tcp
 match access-group name ACL-MGMT-SSH
class-map type inspect match-any CM-ICMP
 match protocol icmp
!
! Пользователи -> R1: SSH и ping
policy-map type inspect PM-USERS-SELF
 class type inspect CM-MGMT-SSH
  inspect
 class type inspect CM-ICMP
  inspect
 class class-default
  drop log
! Серверы и DMZ -> R1: только ping
policy-map type inspect PM-INSIDE-SELF
 class type inspect CM-ICMP
  inspect
 class class-default
  drop log
! R1 -> любая зона: собственный трафик с отслеживанием сессий
policy-map type inspect PM-SELF-OUT
 class type inspect CM-ALL
  inspect
 class class-default
  drop log
!
zone-pair security ZP-OUTSIDE-SELF source OUTSIDE destination self
 service-policy type inspect PM-DROP-LOG
zone-pair security ZP-SELF-OUTSIDE source self destination OUTSIDE
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-SERVERS-SELF source SERVERS destination self
 service-policy type inspect PM-INSIDE-SELF
zone-pair security ZP-SELF-SERVERS source self destination SERVERS
```

```
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-DMZ-SELF source DMZ destination self
 service-policy type inspect PM-INSIDE-SELF
zone-pair security ZP-SELF-DMZ source self destination DMZ
 service-policy type inspect PM-SELF-OUT
zone-pair security ZP-USERS-SELF source USERS destination self
 service-policy type inspect PM-USERS-SELF
zone-pair security ZP-SELF-USERS source self destination USERS
 service-policy type inspect PM-SELF-OUT
```

Все двадцать пар зон приведены в таблице 5.

Таблица 5 – Пары зон межсетевого экрана

Пара зон	Политика	Что разрешено
ZP-USERS-SERVERS	PM-USERS-SRV	TCP 22, 80, 443 и ping
ZP-USERS-DMZ	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-USERS-OUTSIDE	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-SERVERS-OUTSIDE	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-DMZ-OUTSIDE	PM-INSPECT-ALL	TCP, UDP, ICMP
ZP-OUTSIDE-DMZ	PM-OUT-DMZ	TCP 80 и 443 к 192.168.20.10, с аудитом
ZP-SERVERS-USERS	PM-DROP-LOG	ничего
ZP-SERVERS-DMZ	PM-DROP-LOG	ничего
ZP-DMZ-USERS	PM-DROP-LOG	ничего
ZP-DMZ-SERVERS	PM-DROP-LOG	ничего
ZP-OUTSIDE-USERS	PM-DROP-LOG	ничего
ZP-OUTSIDE-SERVERS	PM-DROP-LOG	ничего
ZP-USERS-SELF	PM-USERS-SELF	SSH и ping
ZP-SERVERS-SELF	PM-INSIDE-SELF	ping
ZP-DMZ-SELF	PM-INSIDE-SELF	ping
ZP-OUTSIDE-SELF	PM-DROP-LOG	ничего
ZP-SELF-USERS, ZP-SELF-SERVERS, ZP-SELF-DMZ, ZP-SELF-OUTSIDE	PM-SELF-OUT	TCP, UDP, ICMP

Проверка главного требования: узел PC-USER открывает страницу сервера DMZ (рисунок 12), узел PC-SRV на тот же запрос получает тайм-аут, а на маршрутизаторе появляется запись `DROP_PKT` для пары `ZP-SERVERS-DMZ` (рисунок 13).

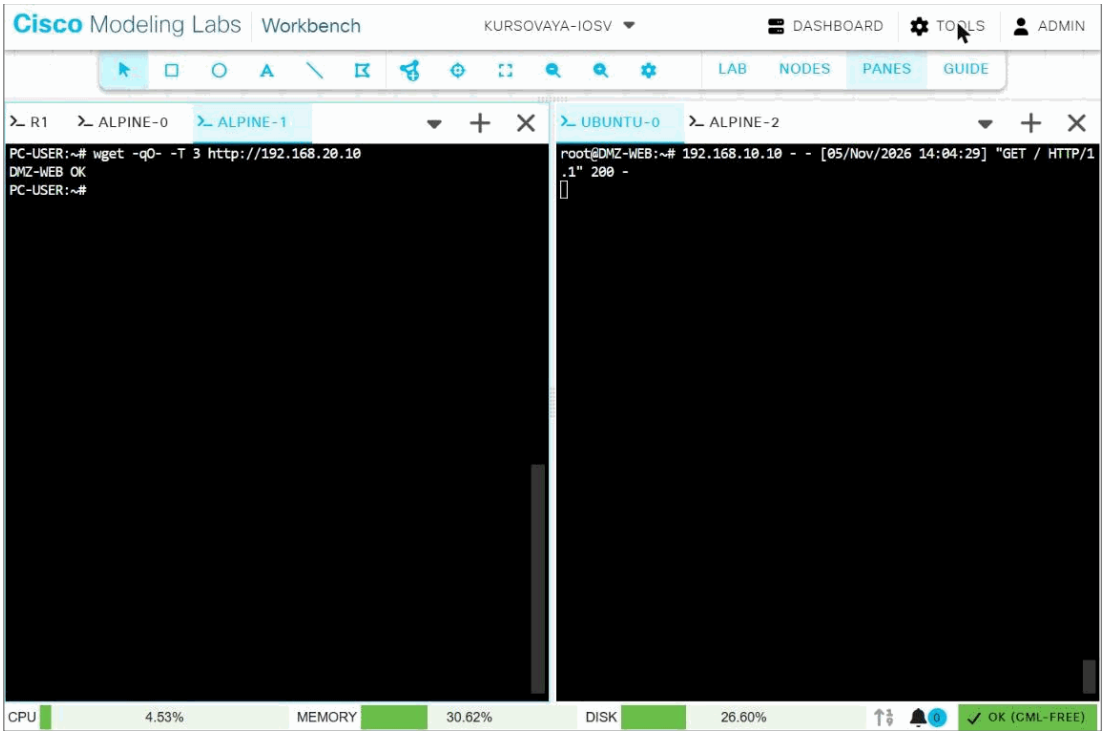


Рисунок 12 – Клиент из сегмента USERS получает доступ к серверу DMZ

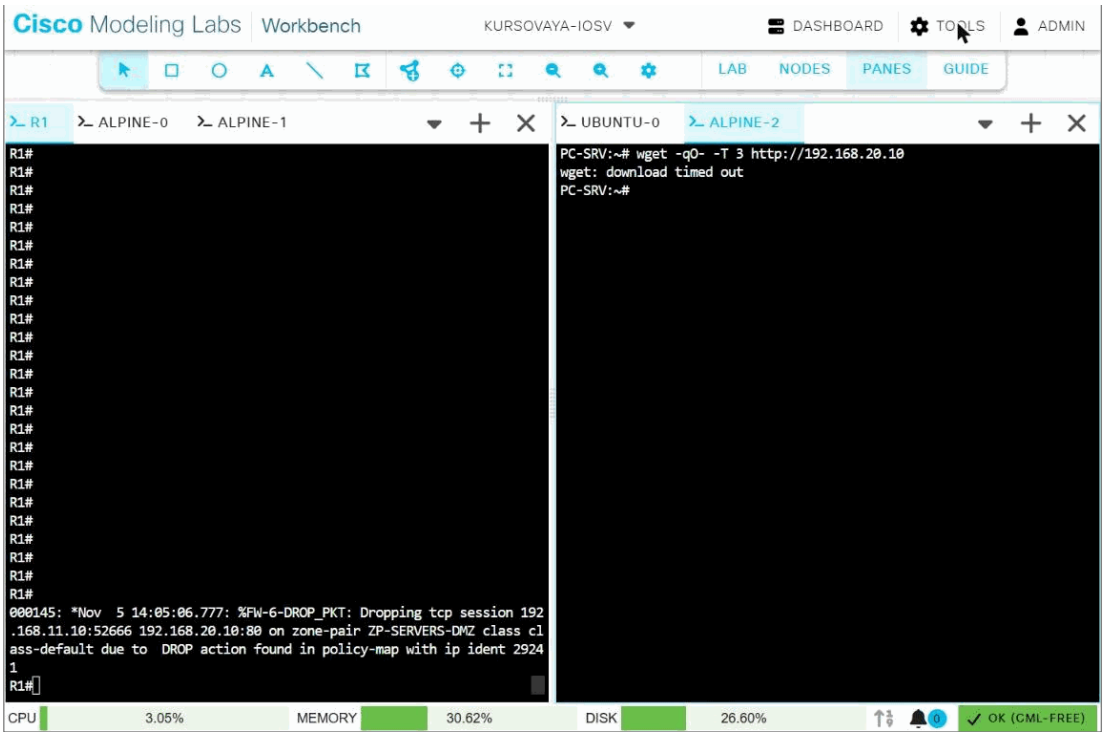


Рисунок 13 – Клиенту из сегмента SERVERS доступ в DMZ запрещён

Сервер DMZ не может начать соединение с внутренними сегментами (рисунок 14). Сканирование 50 портов маршрутизатора из внешней сети не получило ни одного ответа; счётчик пары `ZP-OUTSIDE-SELF` вырос с 0 до 108, по числу пакетов сканера (рисунок 15).

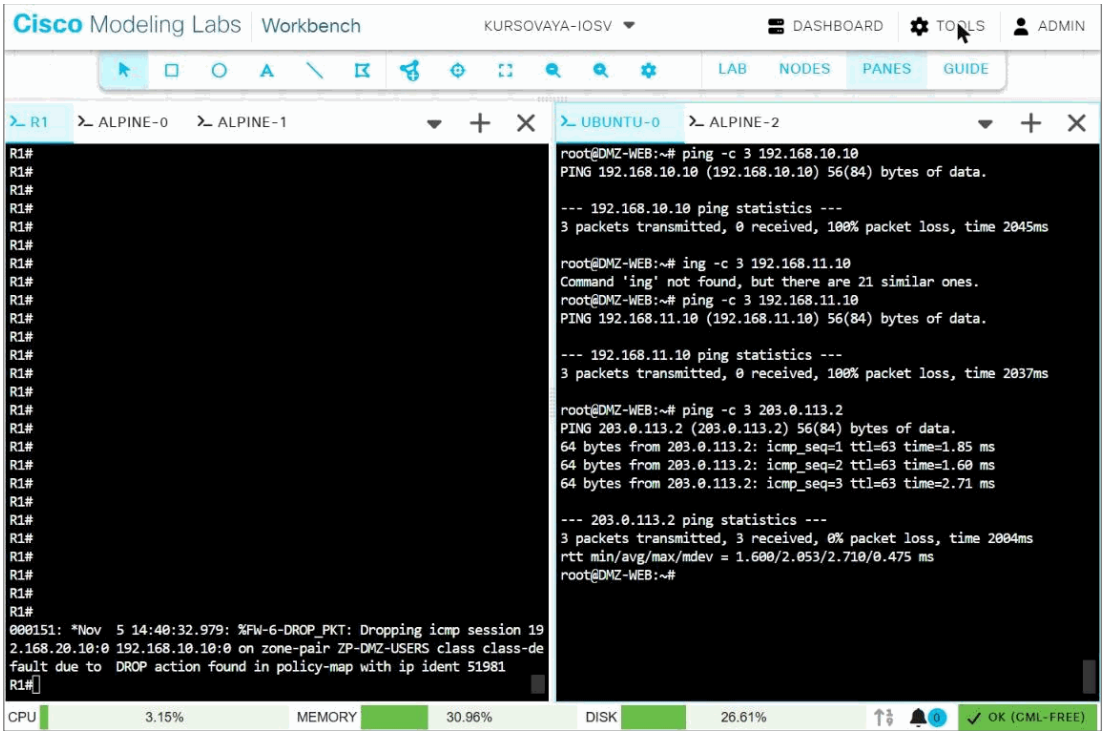


Рисунок 14 – Сервер DMZ не может начать соединение с внутренними сегментами

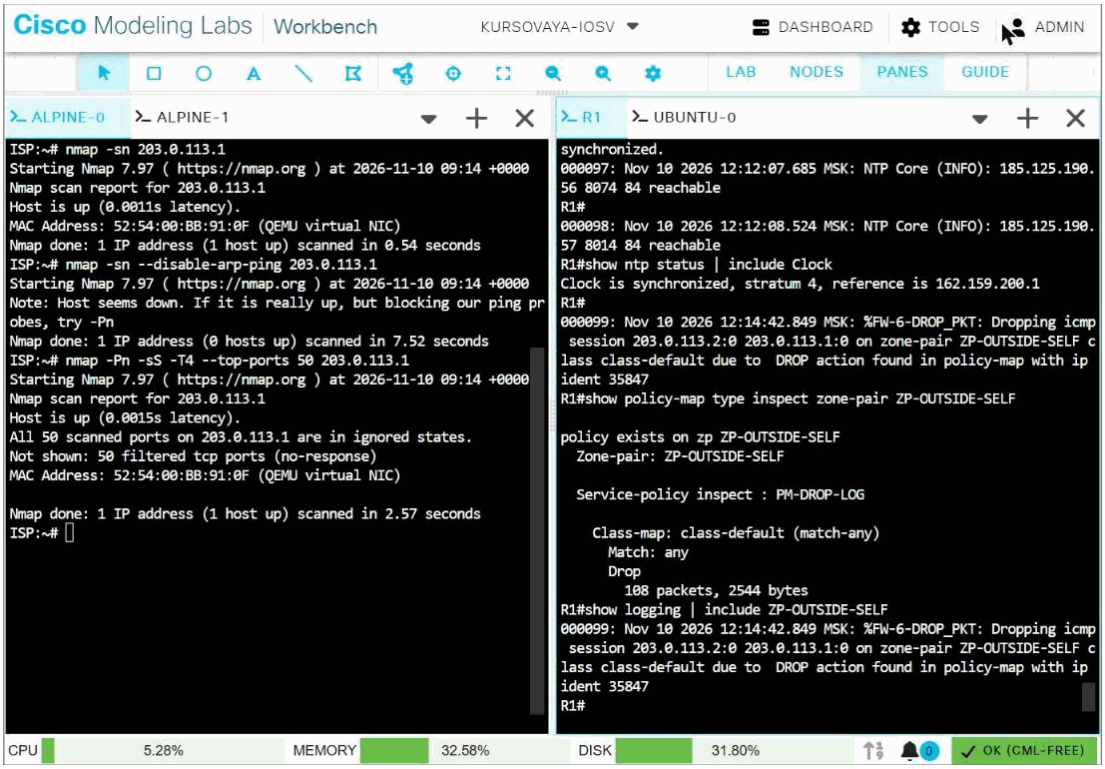


Рисунок 15 – Сканирование портов маршрутизатора извне: ответов нет

4.5. Выход в Интернет и публикация веб-сервера

Внутренние сети имеют частные адреса, и провайдер на них не отвечает. Интерфейсы трёх сегментов объявлены внутренними для трансляции, интерфейс

к провайдеру – внешним. Правило с ключевым словом `overload` заменяет адрес источника на адрес внешнего интерфейса, различая соединения по номеру порта (листинг 14).

Листинг 14 – Трансляция адресов с перегрузкой (PAT)

```
interface GigabitEthernet0/0
 ip nat inside
interface GigabitEthernet0/1
 ip nat inside
interface GigabitEthernet0/2
 ip nat inside
interface GigabitEthernet0/3
 ip nat outside
!
! Чьи адреса транслировать
ip access-list standard NAT-INSIDE
 remark Inside networks translated by PAT
 permit 192.168.10.0 0.0.0.255
 permit 192.168.11.0 0.0.0.255
 permit 192.168.20.0 0.0.0.255
!
! Все перечисленные сети выходят под адресом интерфейса Gi0/3
ip nat inside source list NAT-INSIDE interface GigabitEthernet0/3 overload
```

До настройки провайдер видел частный адрес 192.168.10.10 и не отвечал (рисунок 16). После настройки он видит адрес 203.0.113.1, ответы возвращаются (рисунок 17).

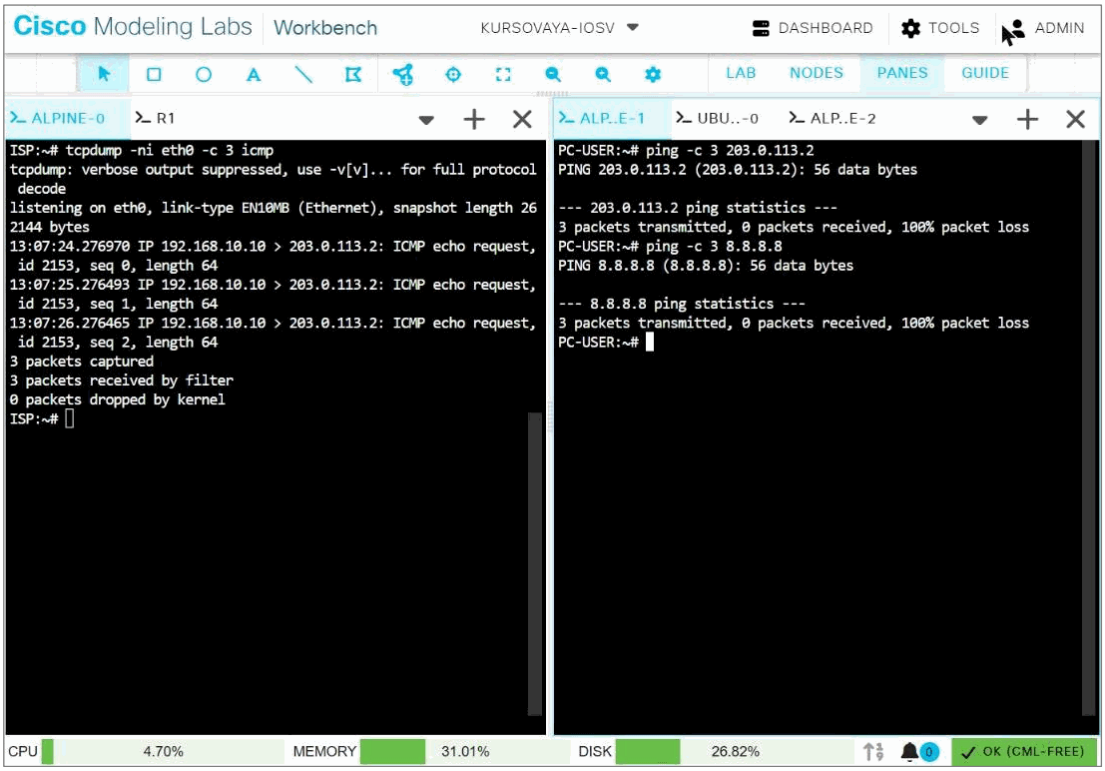


Рисунок 16 – До настройки: провайдер видит частный адрес, ответов нет

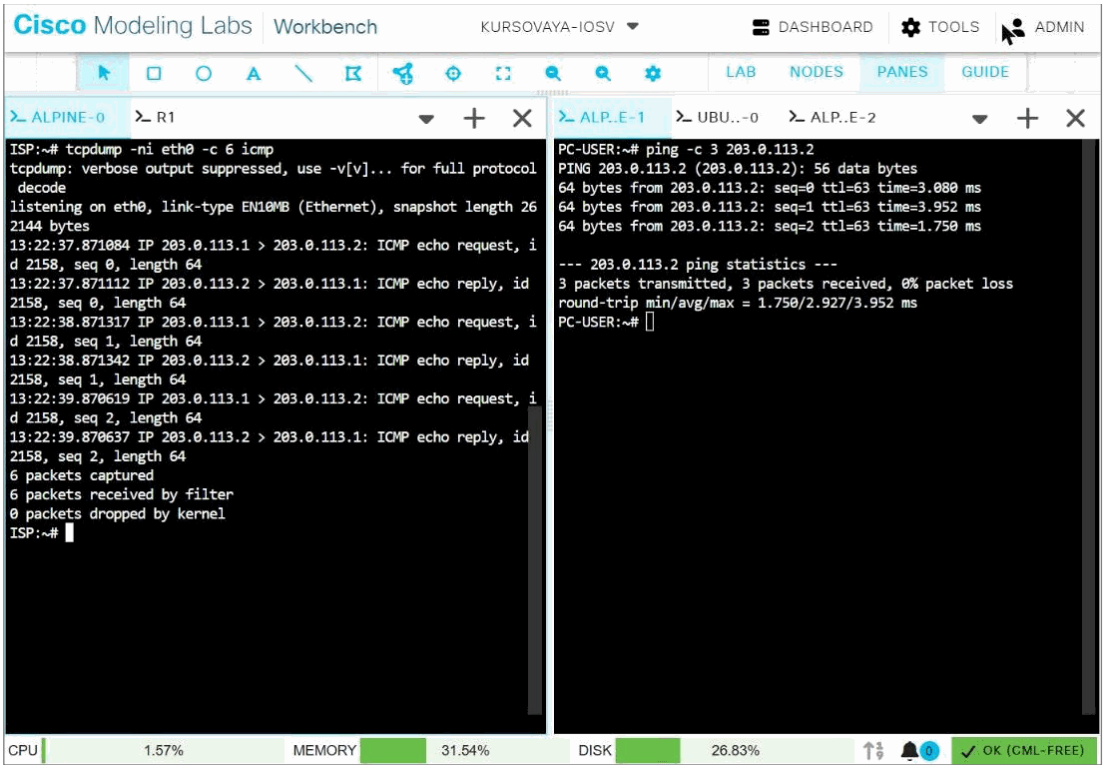


Рисунок 17 – После настройки: провайдер видит публичный адрес R1, ответы возвращаются

Веб-серверу назначен постоянный публичный адрес 203.0.113.3 (листинг 15). Трансляция отвечает только за адрес; какие порты сервера доступны извне, решает экран (пара `ZP-OUTSIDE-DMZ`, порты 80 и 443).

Листинг 15 – Статическая трансляция адреса веб-сервера

```
! 192.168.20.10 <-> 203.0.113.3, в обе стороны
ip nat inside source static 192.168.20.10 203.0.113.3
```

С внешнего узла страница открывается по HTTP и HTTPS (рисунок 18). Сканер портов видит открытыми только порты 80 и 443; порты 22 и 8080 закрыты (рисунок 19).

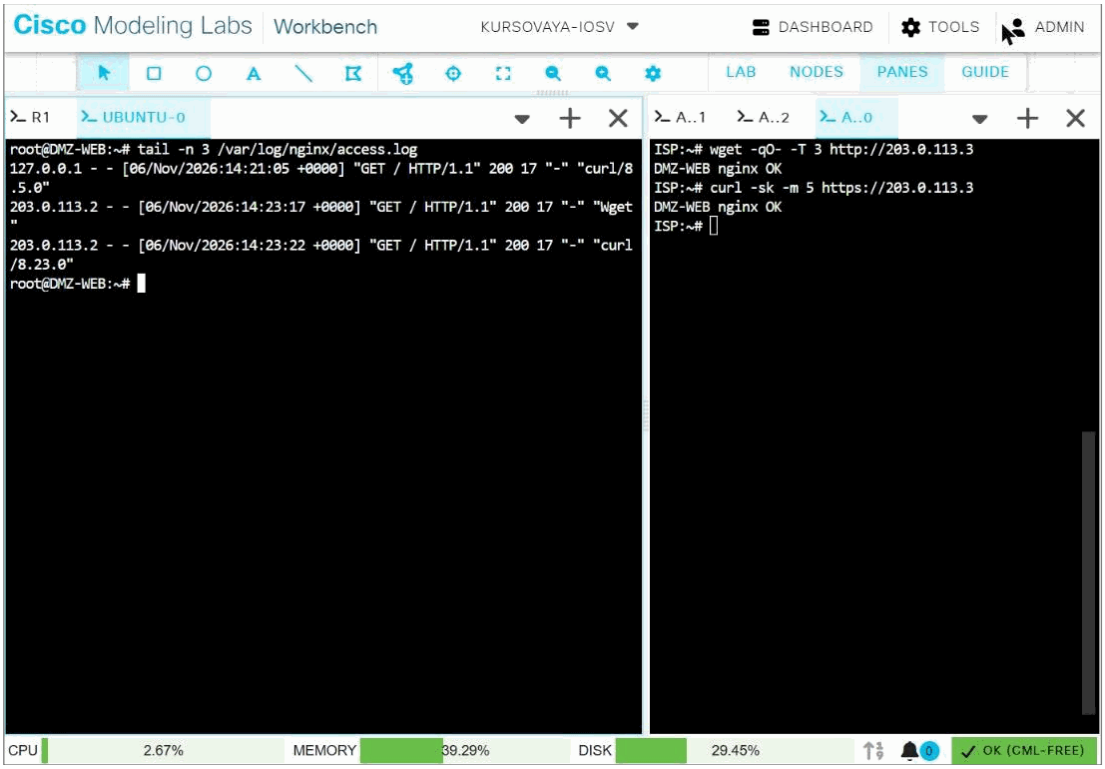


Рисунок 18 – Сайт доступен из внешней сети по HTTP и HTTPS

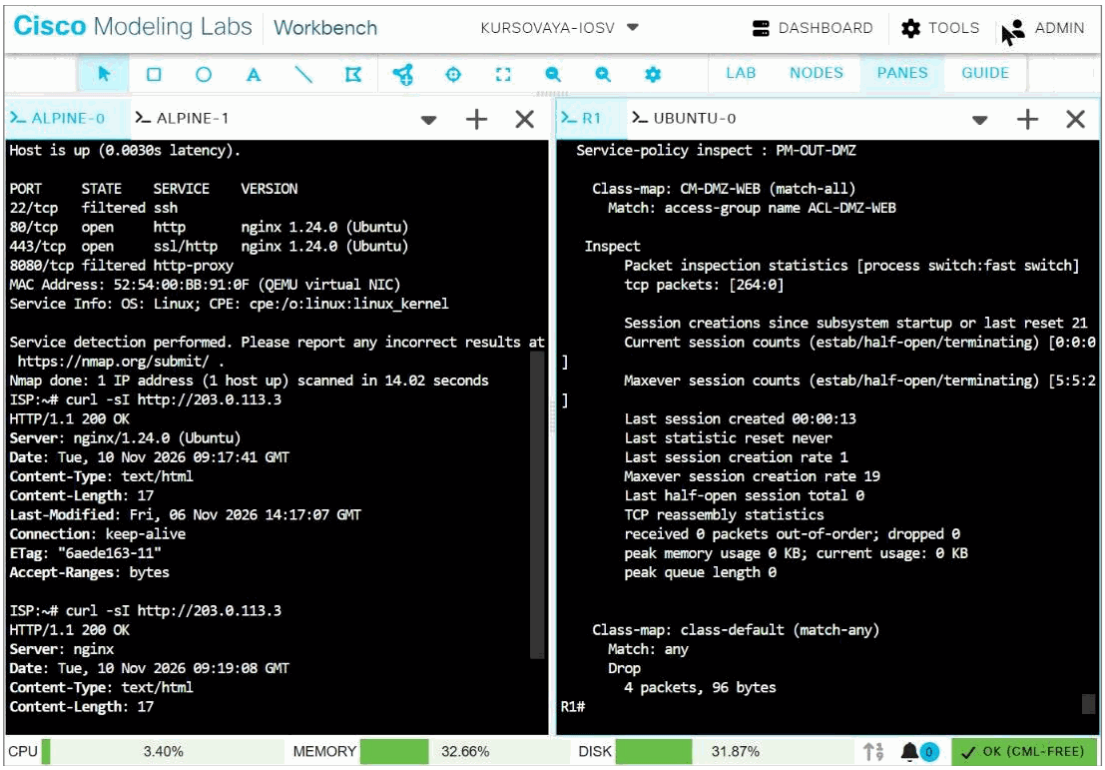


Рисунок 19 – Сканирование веб-сервера извне: открыты только порты 80 и 443

4.6. Время и журнал

Задан часовой пояс, а метка времени в журнале дополнена годом, миллисекундами и названием пояса (листинг 16).

Листинг 16 – Часовой пояс и формат меток времени

```
! Пояс MSK, смещение +3 часа
clock timezone MSK 3 0
! Метка: дата с годом, миллисекунды, местное время, название пояса
service timestamps log datetime msec localtime show-timezone year
service timestamps debug datetime msec localtime show-timezone year
```

Журнал отправляется на сервер в DMZ. Поток сообщений ограничен, чтобы массовая атака не превратила журнал в дополнительную нагрузку (листинг 17). Сервер записывает только сообщения, пришедшие с адреса маршрутизатора.

Листинг 17 – Журнал: буфер, сервер и ограничение потока

```
! Буфер 64000 байт, уровни 0-6
logging buffered 64000 informational
! Сервер журналов; на сервер уходят уровни 0-6 (значение по умолчанию)
logging host 192.168.20.10
! Адрес отправителя - интерфейс в сторону сервера
logging source-interface GigabitEthernet0/2
! Не более 100 сообщений в секунду, кроме warnings и важнее
logging rate-limit 100 except warnings
! Записи списков доступа - не чаще раза в 10 мс
ip access-list logging interval 10
```

Время маршрутизатор получает от трёх серверов NTP и обменивается только с ними (листинг 18).

Листинг 18 – Синхронизация времени по NTP

```
ntp logging
ntp server 185.125.190.56 prefer
ntp server 185.125.190.57
ntp server 162.159.200.1
!
ip access-list standard NTP-PEERS
 remark NTP servers R1 may sync with
 permit host 185.125.190.56
 permit host 185.125.190.57
 permit host 162.159.200.1
! Обмен только с перечисленными серверами
ntp access-group peer NTP-PEERS
```

События разных видов – изменение конфигурации, неудачный вход, отброшенный пакет, пакет с поддельным адресом – появляются на сервере подряд, без пропусков в нумерации (рисунок 20). До настройки одно и то же обращение маршрутизатор и веб-сервер записывали с разницей в несколько секунд, после настройки – в одну и ту же секунду (рисунок 21).

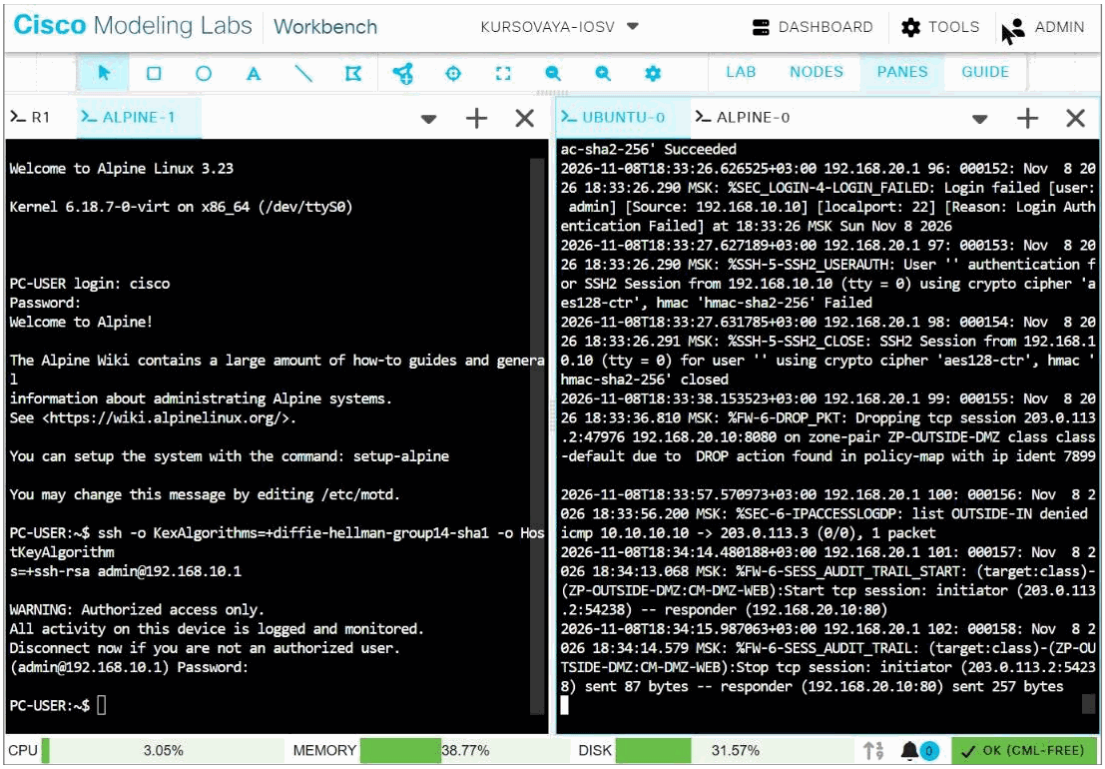


Рисунок 20 – События маршрутизатора в журнале на сервере

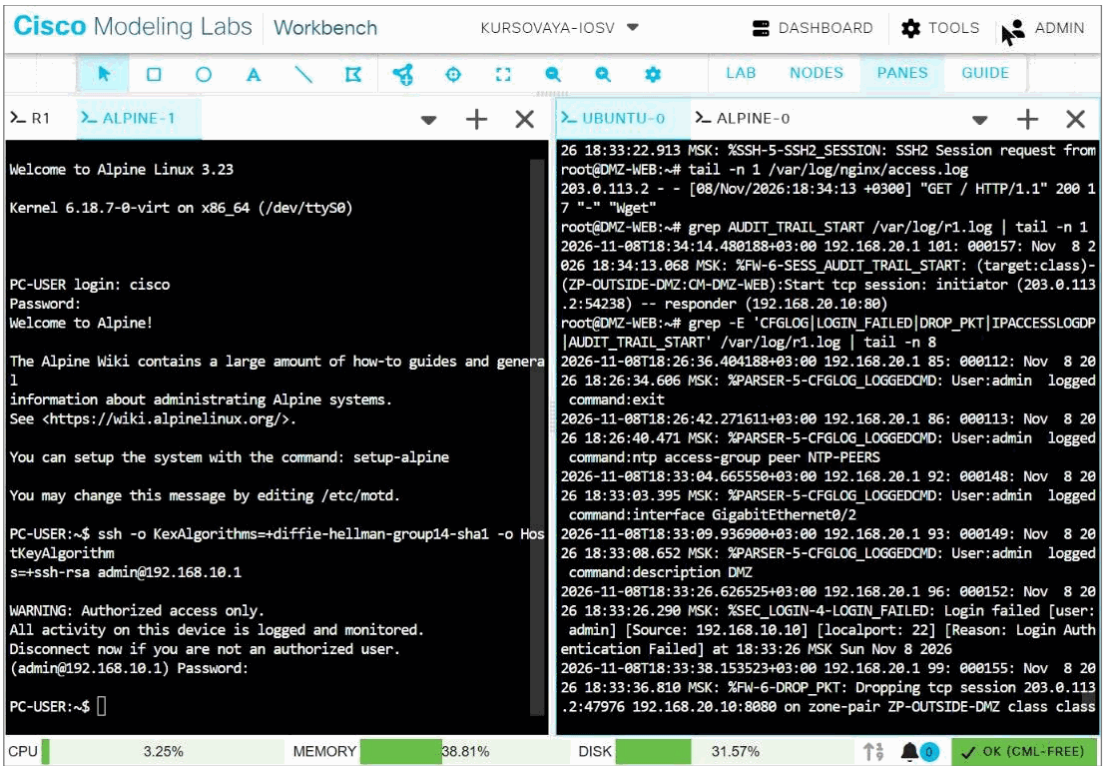


Рисунок 21 – R1 и веб-сервер записали обращение в одну и ту же секунду

5. Проверка защиты атаками

Итоговая конфигурация испытана восемью атаками с внешнего узла с помощью nmap, hping3 и hydra. Конфигурация маршрутизатора во время атак не менялась. Результаты приведены в таблице 6.

Таблица 6 – Результаты атак на итоговую конфигурацию

Угроза	Инструмент	Механизм защиты	Результат
Разведка портов маршрутизатора	nmap	Экран, пара `ZP-OUTSIDE-SELF`	50 портов filtered; счётчик 0 → 108. Отражена
Разведка веб-сервера	nmap	Статическая трансляция и пара `ZP-OUTSIDE-DMZ`	Видны только порты 80 и 443; порты 22 и 8080 filtered
Раскрытие версии программы	curl	Параметр `server_tokens off` на сервере	Версия в ответах сервера скрыта
Выход к внутренним сетям	traceroute, nmap	Трансляция адресов и экран	Узлы недостижимы. Отражена
Подмена адреса источника	hping3	Список OUTSIDE-IN и uRPF	Счётчики +3 и +3; на сервере 0 пакетов. Отражена
Поток пакетов, перегрузка журнала	hping3	Экран и ограничение частоты журнала	Отброшены все пакеты; 4 записи на 2200 отказов; загрузка процессора 3–4 %
Подбор пароля SSH извне	hydra	Экран, пара `ZP-OUTSIDE-SELF`; список на линиях vty	Соединение не устанавливается. Отражена
Подбор пароля SSH изнутри	hydra	Блокировка входа	Тихий режим на 120 с после трёх попыток. Отражена

На рисунке 22 показан поток пакетов на закрытый порт веб-сервера. Отброшены все пакеты, на 2200 отказов в журнале создано четыре записи, загрузка процессора осталась на уровне 3–4 %.

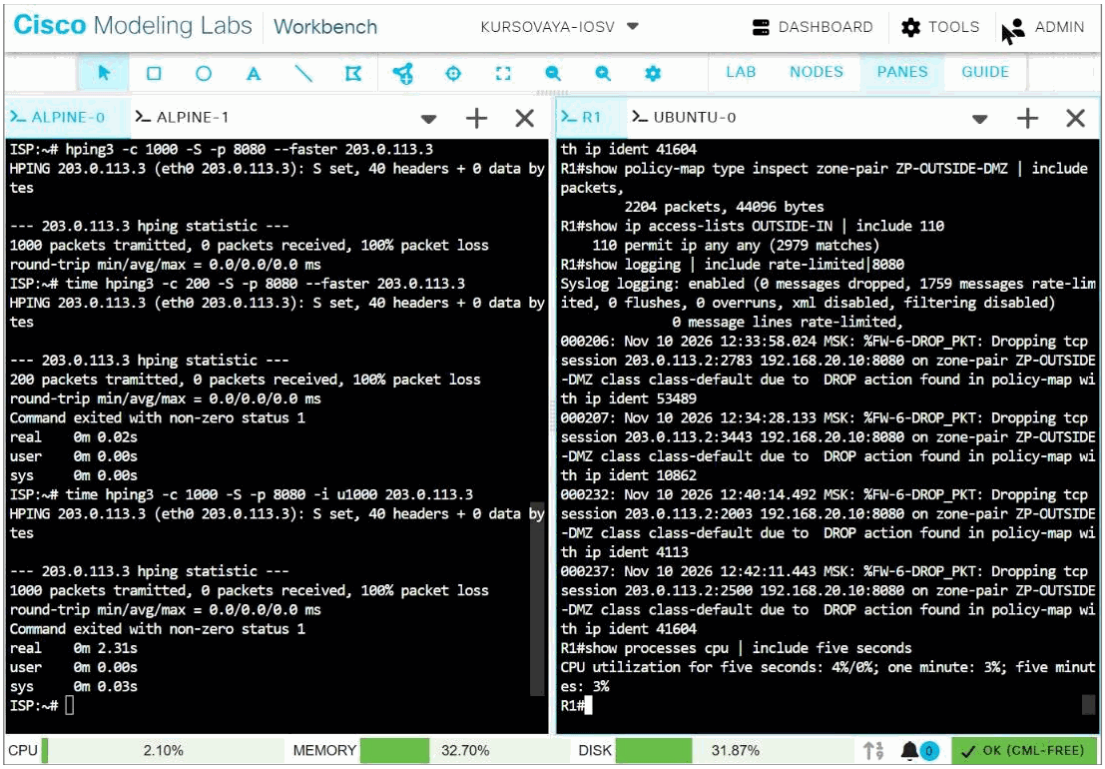


Рисунок 22 – Поток пакетов на закрытый порт: счётчики и ограничение журнала

6. Где применима такая топология

Схема с одним маршрутизатором и тремя внутренними сегментами подходит там, где одновременно выполняются три условия: есть сервис, который должен быть виден из Интернета; есть внутренние данные, которые нельзя открывать наружу; нет средств на отдельный межсетевой экран и специалиста, который бы его обслуживал. Примеры приведены в таблице 7.

Таблица 7 – Примеры применения

Где	Сегмент пользователей	Сегмент серверов	DMZ
Небольшой офис с собственным сайтом или почтой	Рабочие места сотрудников	Файловый сервер, учётная система	Сайт, почтовый сервер
Филиал компании	Рабочие места филиала	Локальный сервер данных	Шлюз для связи с головным офисом, портал для клиентов
Небольшая клиника или учебное заведение	Рабочие места персонала	База данных пациентов или учащихся	Сайт записи, электронный дневник
Магазин, кафе	Рабочие места администрации	Кассовая и складская система	Сайт заказов
Небольшое производство	Офисные компьютеры	Сервер управления оборудованием	Сервер обмена данными с подрядчиками

Во всех этих случаях действует один и тот же принцип: внешний посетитель попадает только на сервер в DMZ и только по нужным портам, а взлом этого сервера не открывает дорогу к внутренним данным. Гостевая беспроводная сеть добавляется в ту же схему как ещё одна зона с выходом только в Интернет.

Схема рассчитана на сеть в несколько десятков рабочих мест. При росте сети её заменяют: ставят отдельный межсетевой экран, размещают DMZ между двумя экранами, резервируют пограничное устройство и канал, вводят централизованную аутентификацию.

7. Ограничения работы

Работа выполнена на учебном стенде, и перед применением в реальной сети конфигурацию нужно доработать.

– Журнал маршрутизатора хранится на веб-сервере DMZ. Причина – в стенде не более пяти узлов. В реальной сети сервер журналов размещают во внутреннем сегменте.

– Исходящий трафик не ограничен: все сегменты могут обращаться в Интернет по любым протоколам.

– Образ IOS 15.9 поддерживает обмен ключами SSH только на основе SHA-1. Современные алгоритмы есть в IOS XE, но в доступном образе IOS XE нет межсетевого экрана на зонах.

– Вся защита находится на одном устройстве без резерва.

– Экран проверяет адреса и порты, но не содержимое соединений.

Полный перечень ограничений и направлений развития приведён в подразделе 4.5 курсовой работы.